M365-22 · Phishing Reporting & Email Threat Response

What a person does when a message looks wrong, and what IT does after they report it.

Field	Value
Document ID	M365-22
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	A. Microsoft 365
Operating tier	Tier 2 — Advanced Technical Services, which already owns malware containment. Escalates to Tier 3 and Tier 4.
Review cycle	Every six months. Attacker technique changes faster than most standards.

1. Purpose

Most tenants already have the technical controls: an external-mail warning banner and a report button. What usually does not exist in writing is what happens after somebody presses it: the triage, the tenant-wide purge, and the decision about whether to tell everybody.

A typical case: a credential-harvesting message titled something like “Account Verification Action Required, Act Fast Now…” gets forwarded to the service desk. That it arrives by forward rather than through the report button is itself a finding, and §2 addresses it.

> **Why this is a short document with a fast clock**
>
> A phishing campaign is a race. The value of a response halves roughly every hour: mail already read cannot be unread, and credentials already entered are already in use. Everything below is arranged to be executed quickly rather than thoroughly.
>
> A partial containment in fifteen minutes beats a complete one in three hours.

2. What the community is asked to do

Ask	Why it is worded that way
Use the Report button in Outlook. Do not forward it to IT.	The button sends the message with its full headers, which is what triage needs, and it feeds the tenant’s own filtering. A forward loses the headers and creates a second copy of a malicious message in a mailbox.
Report it even if you are not sure.	A false positive costs IT two minutes. An unreported real one costs considerably more. Nobody will be made to feel foolish.

Ask	Why it is worded that way
Report it even if you already clicked.	This is the most important line in the document. Somebody who is embarrassed and says nothing is the worst case, and the fear of being blamed is what causes it.
Do not warn colleagues by forwarding it to them.	Well meant, and it spreads the message further. Tell IT and IT will tell everybody (§6).
IT will never ask for your password or an MFA code.	The one rule that defeats most of these attacks on its own (ACC-15, ACC-06).

3. Triage — the first ten minutes

1. Establish what the message is trying to obtain: credentials, a payment, a file, or a reply that starts a conversation. This determines everything that follows.
2. Establish the blast radius. How many mailboxes received it? Search the tenant by sender, subject and URL — not by one of the three.
3. Establish whether anybody interacted. Clicks and credential submissions are what turn a nuisance into an incident.
4. Classify: nuisance (spam, no credential objective), credential harvest, business email compromise, or malware delivery.
5. For anything other than nuisance, tell Tier 3 immediately and do not wait until containment is finished. Two people working in parallel is the point of a tier model.
6. Where credentials may have been submitted, this is a GOV-03 incident and Tier 4 is informed. Do not decide alone whether it is “serious enough”.

4. Containment

1. Purge the message from every mailbox that received it, tenant-wide. Not only the reporter’s.
2. Block the sender, the sending infrastructure and the URLs.
3. Check whether the same campaign arrived under other subjects or senders. Campaigns rarely send one variant.
4. Where one of your own accounts is sending it, that account is compromised. Disable sign-in, revoke sessions and tokens, and go to §5 — an internal sender is a much more serious situation than an external one because it defeats the banner and the recipient’s instincts.
5. Record what was purged and when. This is the evidence for §6 and for any later question about who could have seen it.

5. When somebody has already clicked

Treat the person as a witness rather than a culprit. The information they hold is time-critical and shame delays it.

1. Ask what they entered and where. A username alone is a different situation from a password, and a password plus an approved MFA prompt is different again.

2. Reset the password and revoke every session and refresh token. A password reset alone does not end a session that is already established.
3. Remove and re-register MFA methods. An attacker who got in may have added their own method, which survives a password reset — this is the step most often missed.
4. Check for mailbox rules created by the attacker: auto-forwarding, auto-delete, or rules hiding replies. This is the standard persistence move and it is invisible to the user.
5. Check for new delegations, send-as grants, and OAuth application consents.
6. Check what the mailbox sent while compromised, and whether it phished anybody else internally.
7. Preserve the audit data before remediating where the sequence allows — Tier 3 decides the order when both matter (ACC-03 §10).
8. Tell the person plainly what was done and what to watch for. They will be anxious; a clear account helps, and it makes them likely to report faster next time.

6. Telling the community

Situation	Communication
Nuisance, small radius	None. Do not train people to ignore IT notices by sending one for everything.
Credential harvest, wide radius, purged before interaction	A short notice: what it looked like, that it was removed, and what to do if they interacted. Reassurance plus one action.
Credential harvest with confirmed interaction	A notice, and a direct approach to anybody who interacted. Under GOV-03 and approved by Tier 4.
Compromised internal account sending to your own people	Immediate notice naming the affected address, because recipients will otherwise trust it. Tier 4 approves; do not delay for polish.
Anything involving personal data of others	Tier 4 and GOV-03 only. Notification obligations may apply and are not IT's call.

Notices come from the established IT notification address so that a warning about phishing is not itself indistinguishable from phishing. Include no links, ask for no action beyond "contact the service desk", and say plainly that IT will never ask for a password.

7. Targeted attacks on IT itself

IT is a target twice over: for its own privileged access, and as a route to everybody else's. Two patterns are common enough to treat as expected rather than surprising.

- A request to the service desk from a personal address, naming a real account holder, asking for a reset or an MFA change. ACC-06 is the control and it applies without exception.
- A request that arrives with urgency and resists verification. Urgency plus resistance is the signature. Any suspected attempt against the desk is written up and circulated with the specifics of what the caller said. Specifics teach; policy reminders do not (ACC-06 §11).

8. Service levels

Event	Commitment (per GOV-06)
Reported message, triaged and classified	P2 — 4 coverage hours. Faster in practice; the clock matters.
Credential harvest with wide radius	P1 — purge started within 1 hour of classification.
Confirmed credential submission	P1 — account contained within 30 minutes; GOV-03 incident.
Compromised internal sender	P1 — sign-in disabled immediately; community notice within 1 hour.
Community notice, where warranted	Within 4 hours of containment.

9. Measurement

- Reports per month, and the share arriving via the report button rather than by forward. The second number measures whether §2 has landed.
- Median time from report to purge.
- Confirmed interactions per campaign — the number that matters most.
- Reports from people who had already clicked. A rise here is good news: it means people believe they will not be blamed.

10. Records

Record	Held in	Retention
Reported message with headers, classification, radius	Ticket	3 years
Purge action and scope	Ticket	3 years
Confirmed interactions and remediation performed	Security record (GOV-03)	7 years
Community notices sent	IT communications record	3 years
Attempts against the service desk, with what was said	Security + training record	7 years

11. Related documents

ID	Title	Relationship
GOV-03	Security Incident Response & Escalation Matrix	Takes over at confirmed interaction. Governs §6 notification.
ACC-03	MFA Enrollment, Reset & Account Recovery	§5 remediation, and risky sign-in handling.
ACC-06	Identity Verification Before Any Account Action	The control against §7.
ACC-15	Acceptable Use & Credential-Sharing Standard	The published “IT will never ask” rule.

ID	Title	Relationship
M365-05	Email Alias & Address Change Standard	Look-alike addresses.
M365-16	Retention, Legal Hold & eDiscovery	Where preservation obligations sit.
GOV-05	Knowledge Base Article Standard	Format for Appendix B.
GOV-06	Service Commitments	Supplies §8.

Appendix A — Triage card

	Establish	Then
1	What is it after — credentials, money, a file, or a reply?	Credentials or money → not a nuisance. Tell Tier 3 now.
2	How many mailboxes got it? Search by sender AND subject AND URL.	Wide radius → P1, start the purge.
3	Did anybody click or submit?	Yes → §5 immediately, and GOV-03 incident.
4	Is the sender one of ours?	Yes → that account is compromised. Disable sign-in now, notice within the hour.
5	Purge tenant-wide, block sender and URLs, check for variants.	Record what was purged and when.
6	Does the community need telling?	§6. Notice from the established IT address, no links, no requested action.

Fifteen minutes of partial containment beats three hours of complete containment. Move.

Appendix B — End-user text

If a message looks wrong	Use the Report button in Outlook. That sends us everything we need. Please don’t forward it — a forward loses the technical detail and puts another copy of it in a mailbox.
Not sure?	Report it anyway. It takes us two minutes to check and nobody has ever been made to feel silly for asking.
Already clicked?	Tell us straight away. This is the single most helpful thing you can do, and you will not be in trouble. What we can fix in ten minutes is much harder to fix the next day.
Please don’t warn colleagues by forwarding it	It spreads the message. Tell us and we will tell everyone at once.
We will never ask for your password or a code	Not by email, not on the phone, not in a ticket. If someone does, they are not IT.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.